

CISM® Review Manual

16th Edition — Table of Contents

About This Manual

- Overview
- Organization of This Manual
- Format of This Manual
- Preparing for the CISM Exam
- Getting Started
- Using the CISM Review Manual
- Features in the Review Manual
- Types of Questions on the CISM Exam
- Preparing for the Exam
- Using ISACA Exam Preparation Resources
- About the CISM Review Questions, Answers & Explanations Manual
- About the CISM Review Questions, Answers & Explanations Database

Chapter 1: Information Security Governance

Overview

- Domain 1 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Reading

Part A: Enterprise Governance

1.1 Importance of Information Security Governance

- 1.1.1 Outcomes of Information Security Governance
- 1.1.2 Scope and Charter of Information Security Governance

1.2 Organizational Culture

- 1.2.1 General Rules of Use / Acceptable Use Policy
- 1.2.2 Ethics

1.3 Legal, Regulatory and Contractual Requirements

- 1.3.1 Requirements for Content and Retention of Business Records

1.4 Organizational Structures, Roles and Responsibilities

- 1.4.1 Roles and Responsibilities
 - Skills
 - Board of Directors
 - Senior Management
 - Business Process Owners
 - Steering Committee
 - Chief Information Security Officer
 - Risk Management Roles and Responsibilities

Part B: Information Security Strategy

1.5 Information Security Strategy Development

- 1.5.1 Business Goals and Objectives
- 1.5.2 Information Security Strategy Objectives
- 1.5.3 Ensuring Objective and Business Integration
 - Business Linkages
- 1.5.4 Avoiding Common Pitfalls and Bias
- 1.5.5 The Desired State
 - COBIT
 - Business Model for Information Security
 - Governance, Risk Management and Compliance

1.5.6 Information Security Strategy Development

1.5.7 Elements of a Strategy

- Road Map
- Resources and Constraints—Overview

1.6 Information Governance Frameworks and Standards

1.6.1 Balanced Scorecard

1.6.2 Architectural Approaches

1.6.3 Enterprise Risk Management Frameworks

1.6.4 Information Security/Cybersecurity Management Frameworks and Models

- ISO/IEC 27000 Series
- NIST Cybersecurity Framework
- NIST Risk Management Framework
- Other Approaches

1.7 Strategic Planning

1.7.1 Workforce Composition and Skills

- Organizational Structure
- Centralized and Decentralized Approaches to Coordinating Information Security
- Employee Roles and Responsibilities
- Skills
- Awareness and Education

1.7.2 Assurance Provisions

- Audits
- Compliance Enforcement

1.7.3 Risk Assessment and Management

- Business Impact Analysis
- Resource Dependency Analysis
- Outsourced Services
- Threat Assessment
- Vulnerability Assessment
- Insurance
- Other Organizational Support and Assurance Providers

1.7.4 Action Plan to Implement Strategy

- Gap Analysis—Basis for an Action Plan
- Action Plan Metrics
- Action Plan Intermediate Goals

1.7.5 Information Security Program Objectives

Chapter 2: Information Security Risk Management

Overview

- Domain 2 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Reading

Part A: Information Risk Assessment

2.1 Emerging Risk and Threat Landscape

2.1.1 Risk Identification

2.1.2 Threats

- Internal Threats
- External Threats
- Advanced Persistent Threats

2.1.3 Defining a Risk Management Framework

- Defining the External Environment
- Defining the Internal Environment

2.1.4 Emerging Threats

2.1.5 Risk, Likelihood and Impact

2.1.6 Risk Register

2.2 Vulnerability and Control Deficiency Analysis

2.2.1 Security Control Baselines

2.2.2 Events Affecting Security Baselines

2.3 Risk Analysis, Evaluation and Assessment

- 2.3.1 Determining the Risk Management Context
- 2.3.2 Operational Risk Management
- 2.3.3 Risk Management Integration with IT Life Cycle Management Processes
- 2.3.4 Risk Scenarios
- 2.3.5 Risk Assessment Process
- 2.3.6 Risk Assessment and Analysis Methodologies
 - NIST Risk Assessment Methodology
 - ISO/IEC Process Steps
 - Cascading Risk
- 2.3.7 Other Risk Assessment Approaches
 - Factor Analysis of Information Risk (FAIR)
 - Holistic Approach to Risk Management (HARM)
 - Probabilistic Risk Assessment
- 2.3.8 Risk Analysis
 - Gap Analysis
 - Qualitative Analysis
 - Semi-quantitative (Hybrid) Analysis
 - Quantitative Analysis
 - Other Risk Analysis Methods
- 2.3.9 Risk Evaluation
- 2.3.10 Risk Ranking

Part B: Information Risk Response

2.4 Risk Treatment / Risk Response Options

- 2.4.1 Determining Risk Capacity and Acceptable Risk (Risk Appetite)
- 2.4.2 Risk Response Options
 - Terminate the Activity
 - Transfer the Risk
 - Mitigate the Risk
 - Accept the Risk
- 2.4.3 Risk Acceptance Framework
- 2.4.4 Inherent and Residual Risk
- 2.4.5 Impact
- 2.4.6 Controls
- 2.4.7 Legal and Regulatory Requirements
- 2.4.8 Costs and Benefits

2.5 Risk and Control Ownership

- 2.5.1 Risk Ownership and Accountability
- 2.5.2 Risk Owner
- 2.5.3 Control Owner

2.6 Risk Monitoring and Reporting

- 2.6.1 Risk Monitoring
- 2.6.2 Key Risk Indicators
- 2.6.3 Reporting Changes in Risk
- 2.6.4 Risk Communication, Awareness and Consulting
 - Risk Awareness
- 2.6.5 Documentation

Chapter 3: Information Security Program Development and Management

Overview

- Domain 3 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Reading

Part A: Information Security Program Development

3.1 Information Security Program Overview

- 3.1.1 Information Security Management Trends

- 3.1.2 Essential Elements of an Information Security Program
- 3.1.3 Importance of the Information Security Program
- 3.1.4 Applying the Security Program Business Case
- 3.1.5 Outcomes of Information Security Program Management
 - Strategic Alignment
 - Risk Management
 - Value Delivery
 - Resource Management
 - Performance Measurement
 - Assurance Process Integration

3.2 Information Security Program Resources

- 3.2.1 Information Security Program Objectives
 - Defining Objectives
- 3.2.2 Information Security Program Concepts
 - Management and Process Concepts
 - Technology Resources
- 3.2.3 Scope and Charter of an Information Security Program
- 3.2.4 Common Information Security Program Challenges
 - Management Support
 - Funding
 - Staffing
- 3.2.5 Common Information Security Program Constraints
 - Physical
 - Ethics
 - Culture
 - Organizational Structure
 - Costs
 - Personnel
 - Resources
 - Capabilities
 - Time
 - Technology

3.3 Information Asset Identification and Classification

- 3.3.1 Information Asset Identification and Valuation
- 3.3.2 Information Asset Valuation Strategies
- 3.3.3 Information Asset Classification
- 3.3.4 Methods to Determine Criticality of Assets and Impact of Adverse Events

3.4 Industry Standards and Frameworks for Information Security

- 3.4.1 Enterprise Information Security Architectures
 - Alternative Enterprise Architecture Frameworks
 - Enterprise Architecture Domains
 - Objectives of Information Security Architectures
- 3.4.2 Information Security Management Frameworks
 - COBIT
 - ISO/IEC 27001:2013
 - NIST Cybersecurity Framework
 - NIST Risk Management Framework
- 3.4.3 Information Security Framework Components
 - Technical Components
 - Operational Components
 - Management Components
 - Administrative Components
 - Educational and Informational Components

3.5 Information Security Policies, Procedures and Guidelines

- 3.5.1 Policies
 - Policy Development
- 3.5.2 Standards
 - Standards Development
- 3.5.3 Procedures
- 3.5.4 Guidelines

3.6 Defining an Information Security Program Road Map

3.6.1 Applying Frameworks and Architectures to Create a Program Road Map

- Simplicity and Clarity Through Layering and Modularization
- Business Focus Beyond the Technical Domain
- Architecture and Control Objectives
- Architecture Implementation
- Security Program Management and Administrative Activities
- Program Administration

3.6.2 Developing an Information Security Program Road Map

- Gap Analysis as the Basis for an Action Plan

3.6.3 Life Cycle Principles Supporting the Road Map

3.7 Information Security Program Metrics

3.7.1 Effective Security Metrics

- Governance Implementation Metrics
- Strategic Alignment Metrics
- Risk Management Metrics
- Value Delivery Metrics
- Resource Management Metrics
- Performance Measurement

3.7.2 Security Program Metrics and Monitoring

3.7.3 Metrics Tailored to Enterprise Needs

- Strategic
- Management
- Operational

Part B: Information Security Program Management

3.8 Information Security Control Design and Selection

3.8.1 Managing Risk Through Controls

- IT Controls
- Non-IT Controls
- Layered Defenses
- Technologies

3.8.2 Controls and Countermeasures

3.8.3 Control Categories

3.8.4 Control Design Considerations

3.8.5 Control Methods

- Countermeasures
- Physical and Environmental Controls
- Control Technology Categories
- Technical Control Components and Architecture

3.9 Information Security Control Implementation and Integration

3.9.1 Baseline Controls

3.10 Information Security Control Testing and Evaluation

3.10.1 Control Strength

3.10.2 Control Recommendations

3.10.3 Control Testing and Modification

3.11 Information Security Awareness and Training

3.11.1 Security Awareness Training and Education

3.11.2 Developing an Information Security Awareness Program

3.11.3 Role-Based Training

3.11.4 Training and Education Metrics

3.12 Integration of the Security Program With IT Operations

3.12.1 Personnel, Roles, Skills and Culture

- Roles
- Skills
- Documentation
- Document Maintenance

3.12.2 Information Security Liaison Responsibilities

- Physical/Corporate Security
- IT Audit
- Information Technology

- Business Unit Managers
- Human Resources
- Legal Department
- Employees
- Procurement
- Compliance
- Privacy
- Training
- Quality Assurance
- Insurance
- Third-party Management
- Project Management Office

3.12.3 Cross-Organizational Responsibilities

3.12.4 Issue Resolution through the Information Security Program

- Vendor Management
- Physical and Environmental Factors
- Cultural and Regional Variances
- Logistics

3.12.5 Integration With IT Processes

- Integration
- System Development Life Cycle Processes
- DevOps and DevSecOps
- Change Management
- Configuration Management
- Release Management

3.12.6 Cloud Computing

- Cloud Service Models
- Advantages
- Evaluation of Cloud Service Providers

3.13 Management of External Services and Relationships

3.13.1 Governance of Third-Party Relationships

3.13.2 Third-Party Service Providers

- Outsourcing and Service Providers

3.13.3 Outsourcing Challenges

3.13.4 Outsourcing Contracts

3.13.5 Third-Party Access

3.14 Information Security Program Communications and Reporting

3.14.1 Program Management Evaluation

- Program Objectives
- Compliance Requirements
- Program Management
- Security Operations Management
- Technical Security Management
- Resource Levels

3.14.2 The Plan-Do-Check-Act Cycle

3.14.3 Security Reviews and Audits

- Audits
- Auditors

3.14.4 Compliance Monitoring and Enforcement

- Policy Compliance
- Standards Compliance
- Resolution of Noncompliance Issues
- Compliance Enforcement

3.14.5 Monitoring Approaches

- Monitoring Security Activities in Infrastructure and Business Applications
- Determining Success of Information Security Investments

3.14.6 Measuring Information Security Management Performance

- Measuring Information Security Risk and Loss
- Measuring Support of Organizational Objectives
- Measuring Compliance
- Measuring Operational Productivity
- Measuring Security Cost-Effectiveness
- Measuring Organizational Awareness

- Measuring Effectiveness of Technical Security Architecture
 - Measuring Effectiveness of Management Framework and Resources
 - Measuring Operational Performance
- 3.14.7 Ongoing Monitoring and Communication

Chapter 4: Incident Management

Overview

- Domain 4 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Reading

Part A: Incident Management Readiness

4.1 Incident Management and Incident Response Overview

- 4.1.1 The Relationship Between Incident Management and Incident Response
- 4.1.2 Goals of Incident Management and Incident Response
- 4.1.3 Incident Handling and Incident Management Life Cycle

4.2 Incident Management and Incident Response Plans

- 4.2.1 Importance of Incident Management
- 4.2.2 Outcomes of Incident Management
- 4.2.3 Incident Management Resources
- 4.2.4 Policies and Standards
- 4.2.5 Incident Management Objectives
- 4.2.6 Strategic Alignment
- 4.2.7 Response and Recovery Plan
- 4.2.8 The Role of the Information Security Manager in Incident Management
- 4.2.9 Risk Management
- 4.2.10 Assurance Process Integration
- 4.2.11 Value Delivery
- 4.2.12 Resource Management
- 4.2.13 Defining Incident Management Procedures
- 4.2.14 Detailed Plan of Action for Incident Management
- 4.2.15 Current State of Incident Response Capability
 - History of Incidents
 - Threats
 - Vulnerabilities
- 4.2.16 Developing an Incident Response Plan
 - Elements of an Incident Response Plan
 - Gap Analysis—Basis for an Incident Response Plan
 - Logistics
- 4.2.17 Incident Management and Response Teams
- 4.2.18 Organizing, Training and Equipping the Response Staff
- 4.2.19 Incident Notification Process
- 4.2.20 Challenges in Developing an Incident Management Plan

4.3 Business Impact Analysis

- 4.3.1 Elements of a Business Impact Analysis
- 4.3.2 Benefits of Conducting a Business Impact Analysis

4.4 Business Continuity Plan

- 4.4.1 Integrating Incident Response With Business Continuity
- 4.4.2 Methods for Providing Continuity of Network Services
- 4.4.3 High-Availability Considerations
- 4.4.4 Insurance

4.5 Disaster Recovery Plan

- 4.5.1 Business Continuity and Disaster Recovery Procedures
- 4.5.2 Recovery Operations
- 4.5.3 Evaluating Recovery Strategies
- 4.5.4 Addressing Threats
- 4.5.5 Recovery Sites

- 4.5.6 Basis for Recovery Site Selections
- 4.5.7 Response and Recovery Strategy Implementation

4.6 Incident Classification / Categorization

- 4.6.1 Escalation Process for Effective Incident Management
- 4.6.2 Help/Service Desk Processes for Identifying Security Incidents

4.7 Incident Management Training, Testing and Evaluation

- 4.7.1 Incident Management Roles and Responsibilities
 - Senior Management Commitment
 - Responsibilities
- 4.7.2 Incident Management Metrics and Indicators
 - Recovery Time Objectives
 - Recovery Point Objectives
 - Service Delivery Objectives
 - Maximum Tolerable Outage
 - Allowable Interruption Window
- 4.7.3 Performance Measurement
- 4.7.4 Updating Recovery Plans
- 4.7.5 Testing Incident Response and Business Continuity/Disaster Recovery Plans
- 4.7.6 Periodic Testing of the Response and Recovery Plans
- 4.7.7 Testing for Infrastructure and Critical Business Applications
- 4.7.8 Types of Tests
- 4.7.9 Test Results
- 4.7.10 Recovery Test Metrics

Part B: Incident Management Operations

4.8 Incident Management Tools and Technologies

- 4.8.1 Incident Management Systems
 - Endpoint Detection and Response
 - Extended Detection and Response
 - Managed Detection and Response
- 4.8.2 Incident Response Technology Foundations
- 4.8.3 Personnel
 - Incident Response Team Organization
 - Roles and Responsibilities
- 4.8.4 Skills
- 4.8.5 Awareness and Education
- 4.8.6 Audits
- 4.8.7 Outsourced Security Providers

4.9 Incident Investigation and Evaluation

- 4.9.1 Executing Response and Recovery Plans
 - Ensuring Execution as Required

4.10 Incident Containment Methods

4.11 Incident Response Communications

- 4.11.1 Notification Requirements
- 4.11.2 Communication Networks

4.12 Incident Eradication and Recovery

- 4.12.1 Eradication Activities
- 4.12.2 Recovery

4.13 Post-Incident Review Practices

- 4.13.1 Identifying Causes and Corrective Actions
 - 4.13.2 Documenting Events
 - 4.13.3 Establishing Legal Procedures to Assist in Post-incident Activities
 - 4.13.4 Requirements for Evidence
 - 4.13.5 Legal Aspects of Forensic Evidence
-

Note: This Table of Contents excludes Appendix A (CISM Exam General Information), Appendix B (CISM Job Practice), Glossary, and Acronyms as requested. All page numbers have been removed for a clean reference version.